



30-LICENSING-AND-ACTIVATION.md — Getting paid without breaking offline-first



AURA promises that it works with no internet connection. A licensing system that phones home to start contradicts the core promise of the product, and photographers will notice on the first destination wedding with hotel wifi. Offline activation is not a nice-to-have here; it is a correctness requirement.

1. The constraint that shapes everything

A wedding photographer works in a barn in rural Wales, a resort in Bali with a captive portal, and a hotel in Kathmandu with a load-shedding schedule. The licence must be valid in all three, for weeks, with no connection at all.

That rules out: server-side seat checks, per-launch validation, subscription tokens that expire in hours, and anything that treats an offline machine as suspicious.

2. The licence file, frozen contract

```
// crates/aura-license/src/contract/license.rs -- FROZEN CONTRACT
pub struct LicenseFile {
    pub license_id: Uuid,
    pub tier: Tier, // Free | Pro | Studio
    pub issued_to: String, // email, shown in About
    pub issued_at: DateTime<Utc>,
    /// None means perpetual. Subscriptions carry a date plus
```

```

a grace window.
    pub valid_until: Option<DateTime<Utc>>,
    pub grace_days: u32,                // 30
    pub seats: u32,
    pub machine_bindings: Vec<MachineBinding>,
    /// Ed25519 over the canonical serialisation of every field above.
    pub signature: [u8; 64],
}

pub struct MachineBinding {
    /// Stable, salted, non-reversible. Never a raw hardware serial.
    pub machine_hash: [u8; 32],
    pub activated_at: DateTime<Utc>,
    pub label: String,                  // "Studio iMac", set by the user
}

pub enum LicenseState {
    Valid { tier: Tier },
    InGrace { days_left: u32 },
    Expired,
    Invalid { reason: String },         // AURA-SEC-9010
    Free,
}

```

The public key is compiled into the binary. Verification is pure, local and offline: no network call is ever required to determine licence state. A signed file the user holds is the whole mechanism.

3. Activation flows

Online, the normal case. Paste the key, one call to the licence service, receive the signed file, store it. Ten seconds, once.

Offline, the case that earns trust. The app shows a request code derived from the machine hash. The user visits the licence portal on a phone, enters key plus request code, receives a short signed blob, and types or scans it into the app. It works on a mountain with no connection and it is the flow that makes the offline promise credible.

Seat management. Deactivate from the app, or from the portal if the machine is dead or stolen. Studio tier allows a floating pool with a documented reactivation limit rather than a silent one.

4. Rules that avoid punishing paying customers

- **Never block work in progress.** If a licence expires mid-run, the run completes. Always. Enforcement happens at the start of the next project, never in the middle of someone's delivery deadline.
- **Grace is real and generous.** Thirty days after expiry, with a quiet banner rather than a modal. A failed card should not cost a photographer a wedding.
- **Expired means read-only, not locked out.** Existing projects open, export still works for already-processed work, new AI processing is what stops. Holding a customer's own photographs hostage is unacceptable and turns a lapsed renewal into a public complaint.
- **Hardware changes are expected.** A new GPU must not invalidate a licence. The machine hash uses stable, coarse attributes and tolerates partial change.
- **No telemetry in licensing.** Validation is local. The licence service learns nothing about what the photographer processes.
- **The free tier is genuinely useful,** not crippled: full import, browsing, manual culling, and AI processing capped at a project size that lets someone evaluate the product on a real wedding.

5. Failure modes

Failure	Consequence	Guard
Clock rollback to extend a subscription	Trivial bypass	Store a monotonic high-water timestamp; a large backward jump enters grace rather than granting time

Failure	Consequence	Guard
Clock forward jump on a broken CMOS battery	Paying user locked out	Implausible future dates are ignored, not enforced
Licence file deleted or corrupted	Panic during a delivery week	Redundant copy in the OS keychain; automatic silent recovery
Licence service down	Nobody can activate	Offline activation path always available; service outage never affects existing installs
Machine hash unstable	Repeated reactivation, angry support tickets	Stability test across driver updates, OS upgrades, docking and undocking
Cracked build circulating	Lost revenue, unsupported users filing bug reports	Accept it. Signature verification plus a fair price is the right level of effort; aggressive DRM costs more in support and goodwill than it recovers

6. Tests

- ☐ Airplane-mode test: activate offline, run a full wedding, relaunch ten times over thirty days with no connection.
- ☐ Tamper test: flip one byte in the licence file; assert `Invalid` with `AURA-SEC-9010` and a clear recovery message.
- ☐ Clock-rollback test: set the clock back one year; assert no extra entitlement is granted.
- ☐ Clock-forward test: set the clock forward five years; assert the user is not locked out.
- ☐ Expiry-mid-run test: expire the licence at 50 percent of a run; assert the run completes.
- ☐ Hardware-change test: change GPU, RAM and hostname; assert the licence survives.
- ☐ Deletion-recovery test: delete the licence file; assert silent recovery from the keychain.

- ☐ Service-outage test: block the licence domain; assert existing installs are wholly unaffected.
- ☐ Free-tier test: complete a real evaluation wedding without paying.

7. Acceptance criteria

- ☐ `license.rs` matches section 2 and is under contract freeze.
- ☐ No network call is required for any licence state determination; proven by architecture test.
- ☐ Offline activation is documented in-app and completes in under two minutes when timed with a real user.
- ☐ Expiry never interrupts a run and never blocks access to existing work.
- ☐ Machine hash proven stable across the full hardware-change matrix.
- ☐ The licence service can be offline for a week with zero customer impact.
- ☐ Pricing and tier limits are stated on one page a photographer can read in a minute.

8. Claude Code prompt

Act as `MBE` (Backend) with `SEC` reviewing. Implement `30-LICENSING-AND-ACTIVATION.md`: the frozen `LicenseFile` contract, offline Ed25519 verification with a compiled-in public key, the stable machine hash, both activation flows including the offline request-code path, keychain redundancy, the monotonic clock high-water mark, and grace handling.

Constraints: no network call may be required to determine licence state; no licence check may run during an active processing run; a licence problem must never prevent opening or exporting existing work; the machine hash must never contain a reversible hardware serial.

Then run the airplane-mode, clock-rollback, clock-forward and hardware-change tests and paste the outputs. Then act as `PM` and review every user-facing licensing string for tone: nothing accusatory, nothing that implies the user is a suspected pirate.